Building secure messaging is hard: A nuanced take on the Bitchat security debate

Jim Miller July 18, 2025 cryptography

Last weekend, when Jack Dorsey released Bitchat, a Bluetooth-based, end-to-end encrypted messaging app, it immediately sparked debate across the security and tech communities. The response has been polarized: **glowing coverage** from mainstream tech outlets celebrates its "advanced security" features, and sharp criticism from **security researchers** and **tech reporters** highlights serious vulnerabilities. Both extremes bear some truth, but they also miss the mark and reveal gaps in how we discuss security in emerging products.

The security issues are real and serious

The security vulnerabilities identified by researcher Alex Radocea and others are legitimate and concerning. Radocea demonstrated a man-in-the-middle (MitM) attack that exploits Bitchat's broken identity authentication system, allowing attackers to impersonate trusted contacts. The app also currently doesn't reach the industry standard level of forward secrecy; the app has forward secrecy at the "session" level, but the encryption keys are static for each "session." The standard approach is to use techniques like the **Double Ratchet**, which achieves forward secrecy at a per-message level, but this is only a concern for niche threat models that require per-message forward secrecy.

These aren't minor implementation bugs; they're fundamental design flaws that compromise the core security promises of an encrypted messaging app. Alex's technical analysis is sound, and his proof-of-

Search...

your@email.com

Subscribe

PAGE CONTENT

The security issues are real and serious

But the broader narrative deserves scrutiny

The broader challenges of secure messaging

A more productive path forward

RECENT POSTS

Your AI agent fixed the bug, but what else did it change?

Package managers have an integrity problem

SequenceHash: multihashing for the rest of us

Don't let TEEs break your MPC

SAML: A fractal of bad design

concept attack effectively demonstrates the risks. Users should absolutely not rely on Bitchat for sensitive communications in its current state.

But the broader narrative deserves scrutiny

However, both the harsh criticism and uncritical praise reveal problematic approaches to evaluating security in emerging products.

On the critical side, while Alex Radocea and journalist Lorenzo Franceschi-Bicchierai correctly identified serious flaws, both posts implied that these vulnerabilities demonstrate a fundamental lack of seriousness about security. But this ignores several positive signals from Dorsey:

- He open-sourced the complete codebase and protocol documentation, making security review possible.
- He included prominent warnings that the software hadn't received a security review.
- He responded to reported vulnerabilities within hours, patching a buffer overflow issue in under four hours.
- In a post on July 15, **he announced** that he has updated the project to now use the well-established Noise protocol framework, directly addressing the authentication concerns.

Dorsey explained in a **follow-up announcement** that Bitchat began as a weekend project to explore Bluetooth mesh networking and encryption models, acknowledging that while the basic functionality "worked within a day," the security implementation was "in no way robust or thought through enough."

On the uncritical side, mainstream tech coverage has been embarrassingly naive. TechRepublic's J.R. Johnivan wrote that Bitchat's "combination of general functionality, security features, and privacy controls sets Bitchat apart from messaging apps like Facebook Messenger, WhatsApp, Snapchat, Telegram." This comparison is absurd. Products like WhatsApp have spent years developing and refining their security and privacy, undergoing extensive audits and real-world testing. Claiming that a week-old app with known vulnerabilities surpasses battle-tested implementations reveals a fundamental misunderstanding of security maturity.

Such coverage demonstrates the tech media's chronic inability to meaningfully evaluate security claims, instead defaulting to marketing language and feature checklists.

The broader challenges of secure messaging

This discourse also highlights how genuinely difficult building secure end-to-end encryption systems really is. The problems Bitchat faces aren't unique or easily solved:

Authentication and key verification remain unsolved at scale. Alex correctly notes that QR codes and fingerprint verification can address MITM attacks, but **as research shows**, these solutions have major usability limitations. Most Signal users rarely verify safety numbers, potentially allowing for a MitM attack similar to what Bitchat currently has (although, notably, that MitM would be much more difficult than the current MitM attack against Bitchat, which is fairly easy to achieve). The more robust solution is key transparency systems, but they require massive infrastructure and an active auditing community, which is why only mature and resourced organizations like Google, Signal, and Meta have successfully deployed them. Moreover, these transparency systems are a natural fit for centralized systems like Signal. Bitchat, on the other hand, is a serverless design that does not have a centralized entity capable of operating the transparency log. Conceivably, a decentralized variant of these transparency systems could be designed, but this is likely significantly more complex and has not been deployed at scale by any system yet.

Protocol extensions create new attack surfaces. While we advocate for using proven protocols like Signal or Noise, real-world messaging apps need features beyond basic message exchange. Signal itself has faced security challenges when implementing novel features such as contact discovery, with **researchers demonstrating attacks** that could enumerate all US phone numbers registered with the service. Every feature addition creates new security considerations.

A more productive path forward

The intense reaction to Bitchat illustrates both the security community's appropriate high standards and some problematic

tendencies in how we evaluate new projects.

Dorsey deserves criticism for the way he framed the release. Despite including security warnings in the README, he immediately discussed using Bitchat in high-risk scenarios like protests in Kenya, which are exactly the sensitive use cases his own warnings advised against. When you're Jack Dorsey and know the tech media will amplify anything you release, you have a responsibility to be more careful about messaging and expectations.

But the response also reveals concerning patterns in security discourse. The immediate assumption that vulnerabilities indicate a lack of seriousness about security creates perverse incentives, as it shames and discourages open source releases and transparent security discussions.

The security community should maintain high standards while also recognizing that security is a process, not a binary state. Bitchat's current vulnerabilities are serious, but Dorsey's response of open-sourcing the code, welcoming security research, rapidly patching issues, and committing to proven protocols are good security practices.

As Dorsey noted today, he "struck a nerve" with this release. That's actually a great thing to see. When products claim "end-to-end encryption," the security community rightfully holds them to the high standards set by Signal and similar tools. This scrutiny protects users and maintains the meaning of security claims.

But we can maintain these standards while also encouraging the kind of open, iterative security development that ultimately makes all of us safer. The goal should be helping projects like Bitchat mature securely, not dismissing them entirely at the first sign of vulnerabilities.

The real test for Bitchat isn't whether it launched with perfect security. Instead, it's whether Dorsey follows through on his commitments to address the identified issues and adopt proven cryptographic practices. The early signs are promising, as Dorsey has committed to implementing the Noise protocol and emphasizes: "serious PRs and audits always appreciated." However, ultimately, actions will matter more than promises.

If you enjoyed this post, share it:

X LinkedIn GitHub Mastodon

Y Hacker News

Related Posts

What we learned reviewing one of the first DKLs23 libraries from Silence Laboratories

June 10, 2025

In October 2023, we audited Silence Laboratories' DKLs23 threshold signature scheme (TSS) library—one of the first ...

A deep dive into Axiom's Halo2 circuits

May 30, 2025

Over two audits in 2023, we reviewed a blockchain system developed by Axiom that allows computing over the entire ...

Cryptographic design review of Ockam

March 5, 2024

In October 2023, Ockam hired Trail of Bits to review the design of its product, a set of protocols that aims to enable ...

© 2026 Trail of Bits. Generated with Hugo and Roadster theme.